

SECURE SOFTWARE DEVELOPMENT LIFE CYCLE POLICY

Version 1.0

Revision Date: August 18, 2026

Contact: security@prompthalo.com



DOCUMENT INFORMATION

Document Family	Governance, Ethics, and Security
Document Title	Secure Software Development Life Cycle Policy
Document ID	POL-SDLC-001
Current Version	1.0
Approved Date	August 18, 2026
Approved By	Information Security Steering Committee
Effective Date	August 18, 2026
Next Review Date	August 18, 2027
Classification	Internal
Document Owner	Chief Executive Officer — Accountable Party
Prepared By	Security Officer
Review Cycle	Annual, or upon material change
Supersedes	N/A
Audience	All personnel, including employees and contractors

APPROVERS AND OWNERS

Name	Role	Information Security Role	Signature	Date
Madhuri Chandoor	Approver	CEO and Founder		August 18, 2026
Praveen Sharma	Owner / Author	Fractional CISO/Security Officer		August 18, 2026

COMPLIANCE

This Policy is authorized by the Information Security Policy (POL-ISP-001) and supports the SOC 2 Trust Services Criterion CC8.1. Change control lives in the Change Management Policy; this Policy adds only what is specific to building software securely.

DOCUMENT VALIDITY

This document is valid only in its published electronic form in the PromptHalo Technologies policy repository. Printed or locally saved copies are uncontrolled and must be verified against the published version before use. This document is classified Internal and may not be distributed outside PromptHalo Technologies or its authorized clients without the written approval of the Security Officer.

TABLE OF CONTENTS

2 1 OVERVIEW AND PURPOSE5

3 2 SCOPE5

4 3 ROLES AND DEFINITIONS.....5

5 4 TERMINOLOGY5

6 5 BUILDING SECURELY6

7 6 TESTING6

8 7 RECORDS.....7

9 8 EXCEPTIONS7

10 9 REFERENCE.....7

11 10 DOCUMENT POLICY HISTORY.....7

12

1 Overview and Purpose

PromptHalo Technologies (“the Company”) builds software. This Policy says what security means while building it, without repeating the change control that the Change Management Policy already covers.

It is short deliberately. Most of what a secure development policy normally contains is either in Change Management, in the Cloud Platform Standard, or in the Vulnerability and Patch Management Policy, and duplicating it here would create two versions to keep in step.

2 Scope

This Policy covers software the Company writes, including the prompts, tool definitions and retrieval configuration that shape how its AI systems behave.

3 Roles and Definitions

1. "The Company" refers to PromptHalo Technologies.
2. The CEO or, in their absence, the Security Officer (the “Accountable Party”) owns this policy, oversees its implementation and enforcement, and may delegate specific duties to a designee. [SOC 2: CC1.3]
3. The Information Security Steering Committee approves this policy and reviews it at least annually. [SOC 2: CC1.2, CC5.3]

4 Terminology

The following terms have the meanings given below wherever they appear in this policy.

1. **Accountable Party** — the CEO or, in their absence, the Security Officer, who owns this policy.
2. **Confidential information** — information classified Confidential or Restricted under the Data Classification Policy, including customer data.
3. **Control** — an activity, automated or manual, performed on a defined cadence that produces evidence it occurred.
4. **Deficiency** — a control that is absent, not operating as described, or not producing evidence.
5. **Dependency** — third-party code the Company's software relies on at build or run time.
6. **Information Security Steering Committee** — the Company's oversight body for information security. At the Company's current size, the Committee comprises the CEO, and every reference in this policy to a decision, approval, review or report of the Committee is satisfied by a dated written record made or confirmed by the CEO; a formal meeting is not required. [SOC 2: CC1.2, CC1.3]
7. **Personnel** — employees, officers, contractors, consultants, interns and temporary workers of the Company.
8. **Security Officer** — the individual accountable for day-to-day operation of the security program.

- 46 9. **Significant change** — a change meeting the trigger criteria in the Risk Management Policy that
47 requires risk reassessment.
- 48 10. **Subservice organization** — a third party whose controls the Company relies upon and which is
49 carved out of the Company's report.
- 50 11. **Threat modelling** — thinking through how a feature could be misused, before it is built.

51 **5 Building Securely**

- 52 1. Security requirements are considered when a feature is designed, not retrofitted. For anything
53 handling client information or granting access, that means a short conversation about how it
54 could be misused, recorded in the issue. [SOC 2: CC8.1]
- 55 2. Code is reviewed by someone other than its author before it reaches production, under the
56 Change Management Policy. Security impact is part of that review rather than a separate gate.
57 [SOC 2: CC8.1]
- 58 3. Dependencies are scanned continuously and secrets are scanned on commit, under the
59 Vulnerability and Patch Management Policy. [SOC 2: CC7.1, CC8.1]
- 60 4. Test and development environments do not hold real client information. Where realistic data is
61 needed, it is synthetic or masked. [SOC 2: CC8.1 · C1.1]
- 62 5. Prompts, tool definitions and retrieval configuration are treated as code held in the repository,
63 reviewed, and changed through the same path. [SOC 2: CC8.1]
- 64 6. A record of what the software is built from — its dependencies and their versions — is produced
65 by the build rather than maintained by hand. When an advisory lands, the question “do we use
66 that” is answered in minutes rather than by reading code. [SOC 2: CC7.1, CC2.1]

67 **6 Testing**

68 Testing is proportionate to what is being built, and most of it is automatic.

- 69 1. Static analysis and dependency scanning run in the pipeline on every change, so a weakness is
70 found at review rather than after release. [SOC 2: CC7.1, CC8.1]
- 71 2. Anything reachable from the internet is tested against common web weaknesses before it is first
72 exposed, and again when its attack surface changes materially. At this size that is a focused
73 check rather than a full engagement. [SOC 2: CC7.1]
- 74 3. An independent penetration test is commissioned where a client agreement requires one, or
75 where the Company judges the service has changed enough to warrant it. Findings enter the
76 plan of action like any other. The Company does not commission one on a calendar simply to
77 have a certificate. [SOC 2: CC7.1, CC4.2]
- 78 4. Where the Company tests its own systems, that is distinct from testing a client's, which happens
79 only under an engagement agreement. [SOC 2: CC1.1, CC6.1]

7 Records

1. Design notes or issues recording how a feature could be misused, where one was needed. [SOC 2: CC8.1]
2. Pull requests with reviews, held under the Change Management Policy. [SOC 2: CC8.1]
3. Dependency and secret scanning output. [SOC 2: CC7.1]

8 Exceptions

Where a requirement of this Policy cannot be met, the position is recorded by the Accountable Party with the compensating measure and a review date. Where no exceptions are in force, that is recorded affirmatively at the annual review.

9 Reference

1. SOC 2 Trust Services Criteria, Security category [CC7.1, CC8.1]
2. POL-CM-001 Change Management Policy [SOC 2: CC8.1]
3. POL-VPM-001 Vulnerability and Patch Management Policy [SOC 2: CC7.1]
4. POL-ISP-001 Information Security Policy [SOC 2: CC5.3]
5. STD-CLD-001 Cloud Platform Standard [SOC 2: CC7.1]
6. POL-AI-001 Artificial Intelligence Governance Policy [SOC 2: CC8.1]

10 Document Policy History

Version	Date	Description
1.0	August 18, 2026	Initial policy release